



ENTERPRISE RISK MANAGEMENT DIGITAL SYSTEM ADDENDUM

NUMBER OF USERS

The price quote should be for 40 users

SCOPE

1. Background

Zimbabwe Energy Regulatory Authority (ZERA) seeks to implement an advanced Enterprise Risk Management (ERM) system comparable to leading platforms. The system should leverage automation, analytics, and AI-assisted insights to enhance risk identification, assessment, monitoring, and reporting. The goal is to improve consistency, reduce manual workloads, and strengthen enterprise-wide risk intelligence.

2. Objectives

The ERM system should achieve the following objectives:

1. Provide a centralised, integrated risk repository with versioning and audit trails.
2. Enable AI-assisted risk identification, classification, and early warning signals.
3. Support automated risk scoring using configurable methodologies and data driven insights.
4. Enable predictive analytics and scenario modelling using machine learning where appropriate.
5. Offer automated workflows for risk owners, reviewers, and approvers.

6. Provide dynamic dashboards, board-level reporting, and configurable analytics.
7. Integrate with enterprise systems like SAP.
8. Improve efficiency through automation of control testing, issue tracking, and reporting.
9. Ensure regulatory compliance and alignment with risk frameworks (ISO 31000, COSO ERM).

3. Functional Specifications

i. Governance

- **Policy Management** Centralized repository for all organizational policies, standards, and procedures.
 - a. Policy creation, version control, distribution, and mandatory user acknowledgment tracking
- **Organizational Structure Mapping** Define and map the organizational hierarchy, business processes, and asset inventories to risks and compliance requirements.
- **GRC Strategy Alignment** Ability to link risks, controls, and compliance status
- **Third-Party / Vendor Management** Processes for assessing, monitoring, and managing risks and compliance for external parties and vendors.
 - **Collaboration Tools** Secure channels and tools for teams, auditors, and management to review and resolve issues, risks, and compliance gaps

ii. Risk Management

- Risk identification, assessment, and evaluation (quantitative and qualitative).
- Risk register creation and maintenance.
- Risk scoring, prioritization, and categorization.
- Risk mitigation and control tracking.
- Risk reporting and dashboards.
- Integration with incident/issue management.

iii. Compliance Management

- Mapping to regulatory requirements, standards, or internal policies.
- Automated compliance checklists and assessments.
- Policy management (creation, distribution, acknowledgment).
- Compliance audit tracking and reporting.
- Regulatory change management alerts.
- Control Testing Tracking and reporting on the effectiveness of compliance controls

iv. Incident & Issue Management

- Corrective and preventive action tracking.
- Notifications and escalation workflows.

v. Reporting & Analytics

- Customizable dashboards and reports. (role-based dashboards and reports for executives, managers, and staff).
- Trend analysis for risk and compliance metrics.
- KPI tracking for performance.
- Predictive analytics and risk scoring models.

4. Technical Specifications

Feature	Requirement
Deployment	On-premises deployment options.
Integration	Ability to integrate seamlessly with SAP or other core enterprise systems.
Security	Role-based access control (RBAC), single sign-on (SSO), multi-factor authentication (MFA), and encryption (data at rest and in transit).
Scalability	Must handle large volumes of data (e.g., audit logs, risk data) and support a growing number of simultaneous users.

Feature	Requirement
Audit Trail	Complete, non-repudiable logging of all user actions and system configuration changes for accountability and forensic analysis.
Mobile Access	Optional mobile application or a fully responsive web interface for access on the go.

5. Operational Specifications

- **User Roles:** Admins, Risk personnel, Compliance, Auditors, Executives, and staff.
- **Customization:** Ability to customize risk frameworks, compliance standards, audit checklists, and dashboards.
- **Training & Support:** Vendor-provided onboarding, training, and ongoing support.
- **Updates & Regulatory Content:** Regular updates to compliance libraries and risk frameworks.

6. Advanced Features

- AI-driven risk prediction or anomaly detection.
- Automated regulatory alerts.
- Scenario analysis and Monte Carlo simulations for risk.
- Collaboration tools for teams to review and resolve issues.
- Third-party / vendor risk management.

7. Roles & Responsibilities

- **Project Manager:** Plan, track and report, manage risks and issues for the project.
- **Risk Officer:** Define risk taxonomy, scoring, and acceptance criteria; champion adoption across business units.
- **Network Administrator:** Provide access to systems, perform technical testing, manage integrations, and ensure security compliance.

- **Vendor:** Deliver software licensing, configuration, implementation assistance and documentation.

8. Acceptance Criteria

The ERM system will be accepted when:

1. Configured system meets the documented business requirements and passes User Acceptance Testing (UAT) with signed approvals from Risk Officer, Assistant Internal Audit Manager, Network Administrator and one ZERA representative.
2. Integrations with other systems like SAP pass end-to-end testing.
3. Training delivered and at least one cohort of users successfully completes acceptance tasks.
4. Security and compliance review completed and signed off by Network Administrator , Chief Audit Executive and Corporate Secretary.
5. Go-live checklist completed and ICT Steering Committee approves handover to business-as-usual support.

9. Confidentiality

All project materials, configurations and data are to be treated as confidential and only shared on a need-to-know basis in accordance with ZERA's confidentiality policies.

10. Handover & Support

- A formal handover pack will be delivered including system documentation, run-books, support contacts and known issues.
- Agree ongoing support model: internal support team, vendor SLA, or hybrid model.